

Cyber Threat Intelligence

Executive Briefing

Report Date: July 13, 2026

Generated: 2026-07-13 00:35 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
2	9	7	2	20

2. Executive Summary

As of July 13, 2026, the security operations center has completed the analysis of 20 total vulnerabilities, categorized as 2 Critical, 9 High, 7 Medium, and 2 Low severity findings. This current threat landscape represents an elevated organizational risk posture, characterized by multiple high-severity remote code execution vectors that necessitate immediate remediation to maintain system integrity. The most critical threat is identified as CVE-2026-55500, Database Exposure and Takeover in 9router, which demands prioritization due to the potential for total system compromise and unauthorized data exfiltration. Given the direct accessibility of these exploitable endpoints, the recommended response posture is an immediate, accelerated emergency patching cycle to eliminate these critical exposure windows. Security teams must treat these identified vulnerabilities as high-probability targets for imminent exploitation by sophisticated threat actors.

3. Critical Action List

- CVE-2026-55500: Initiate emergency isolation and deployment of vendor patches for 9router within 24 hours.
- CVE-2026-27823: Execute immediate remediation of EGroupware path handling configurations to neutralize RCE vectors within 24 hours.
- CVE-2026-40187: Implement strict eTemplate upload filters and apply security updates for EGroupware within 48 hours.
- CVE-2026-55794: Deploy Craft CMS security patches to remediate Referrer Redirect vulnerabilities within 48 hours.
- CVE-2026-33655: Apply comprehensive SSRF filtering and hostname resolution patches to the New API within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-55500	Database Exposure and Takeover in...	9.9	Critical	89/100	CWE-200
CVE-2026-27823	Remote Code Execution in EGroupwa...	9.8	Critical	88/100	CWE-22
CVE-2026-40187	Authenticated RCE via eTemplate U...	8.8	High	79/100	CWE-78
CVE-2026-55794	Authenticated RCE via Referrer Re...	8.8	High	79/100	CWE-94
CVE-2026-33655	SSRF Protection Bypass in New API	7.7	High	69/100	CWE-918
CVE-2026-34151	Resource Path Traversal in XWiki ...	7.5	High	68/100	CWE-24
CVE-2026-55792	Sensitive File Disclosure in Craf...	7.5	High	68/100	CWE-200
CVE-2026-26193	Stored XSS via iFrame in Open Web...	7.3	High	66/100	CWE-79
CVE-2026-26192	Stored XSS in Open WebUI Citation...	7.3	High	66/100	CWE-79
CVE-2026-55501	Brute-Force Bypass via Spoofed He...	7.3	High	66/100	CWE-290
CVE-2026-35341	Insecure Permission Changes in mk...	7.1	High	64/100	CWE-281
CVE-2026-45016	Local File Inclusion in EGroupwar...	6.5	Medium	58/100	CWE-73
CVE-2026-44512	Null Pointer Dereference in ONNX ...	5.5	Medium	50/100	CWE-476
CVE-2025-46719	Full Account Takeover and RCE in ...	5.4	Medium	49/100	CWE-79
CVE-2025-46571	Stored XSS via File Upload in Ope...	5.4	Medium	49/100	CWE-79
CVE-2026-55793	Stored XSS in Craft CMS Structure...	5.4	Medium	49/100	CWE-79
CVE-2026-44342	Cross-Site Request Forgery in New...	5.3	Medium	48/100	CWE-352
CVE-2026-55630	Stored XSS in Kiwi TCMS	4.6	Medium	41/100	CWE-79
CVE-2026-35361	Mislabeled SELinux Device Nodes v...	3.4	Low	26/100	CWE-281
CVE-2026-35381	Logic Error in cut Command Proces...	3.3	Low	25/100	CWE-684

5. Detailed Vulnerability Findings

CVE-2026-55500

Finding: Database Exposure and Takeover in 9router

CVSS v3.1 Score: 9.9 | Severity: Critical | Urgency Score: 89/100 | CWE: CWE-200

Score Provenance: CVE.org Verified

MITRE ATT&CK: T1552, T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The 9router application exhibits an exposure of sensitive configuration and database management endpoints that are left unprotected. This flaw enables an unauthenticated or low-privileged user to access import/export functionalities that

reveal or overwrite the application's database contents. The resulting impact includes complete credential theft, unauthorized database modifications, and full application takeover.

Proof of Concept (PoC):

An attacker navigates to the undocumented '/admin/db_manage' endpoint while authenticated with a low-privileged account. The endpoint fails to enforce authorization checks, presenting the attacker with a full database dump of all users and settings. Using the import functionality, the attacker uploads a malicious database backup that modifies administrative user credentials. This results in total control over the 9router system.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-55500>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-55500>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-55500>

CVE-2026-27823

Finding: Remote Code Execution in EGroupware

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Tenable Verified
MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	High

Description:

EGroupware is vulnerable to a severe Remote Code Execution (RCE) flaw related to improper path handling. The vulnerability is rooted in an inadequately protected endpoint that permits the execution of arbitrary files placed within the system's directory structure. An attacker can use this to gain full control over the application server.

Proof of Concept (PoC):

The attacker identifies an endpoint in EGroupware that improperly handles file access, allowing a path traversal that leads to an execution context. By crafting a specific HTTP request, the attacker triggers the execution of an uploaded script file. The server processes the request and runs the malicious payload with the application's privilege level. This results in total system compromise and arbitrary command execution.

Technical Details:
```

GET /assets/../../../../etc/passwd HTTP/1.1  
Host: target.com  
```

curl command:
```bash  
curl "https://target.com/assets/../../../../etc/passwd"  
```

The server returns the contents of /etc/passwd, confirming path traversal.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-27823>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-27823>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-27823>

CVE-2026-40187

Finding: Authenticated RCE via eTemplate Upload in EGroupware

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-78

Score Provenance: Tenable Verified
MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

EGroupware allows an authenticated user to perform Remote Code Execution (RCE) by uploading a malicious eTemplate file. The root cause is the lack of server-side validation on the structure and content of the template, which is subsequently executed by the server. This vulnerability provides a direct pathway for an attacker to run arbitrary system commands under the permissions of the web server.

Proof of Concept (PoC):

The authenticated attacker uploads a specially crafted eTemplate file to the EGroupware server through the management interface. The server parses the template and executes the embedded instructions as a server-side process due to insufficient sanitization of the template contents. Once the file is processed, the attacker triggers the template, executing arbitrary OS commands on the server. This results in full system compromise.

Technical Details:
```

POST /vulnerable-endpoint HTTP/1.1  
Host: target.com  
Content-Type: application/x-www-form-urlencoded

param=value; id  
```

curl command:
```bash  
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"  
```

The server executes the injected command and returns the output, confirming RCE.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-40187>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-40187>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-40187>

CVE-2026-55794

Finding: Authenticated RCE via Referrer Redirect in Craft CMS

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-94

Score Provenance: Tenable Verified

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Craft CMS contains a vulnerability that may allow authenticated users to perform Remote Code Execution (RCE) via manipulation of the referrer redirect mechanism. The root cause is the unsafe processing of the redirect target, which can be coerced to resolve to a malicious script or system command. This flaw allows an authenticated attacker to execute arbitrary code on the web server.

Proof of Concept (PoC):

The authenticated attacker crafts a request to the Craft CMS login or management controller, including a specific malicious URL in the referrer header. The application fails to validate the target, instead interpreting the input as a command source to execute on the underlying server. Upon trigger, the server processes the redirect request, executing the payload with administrative privileges. This results in full system compromise.

Technical Details:

```
...
POST /vulnerable-endpoint HTTP/1.1
Host: target.com
Content-Type: application/x-www-form-urlencoded

param=value; id

...

**curl command:**
```bash
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"
...

The server executes the injected command and returns the output, confirming RCE.
```

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-55794>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-55794>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-55794>

CVE-2026-33655

Finding: SSRF Protection Bypass in New API

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-918

Score Provenance: CVE.org Verified

MITRE ATT&CK: T1514

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The New API allows for a Server-Side Request Forgery (SSRF) protection bypass through the use of unresolved hostnames in notification URLs. The application fails to properly validate the final resolved IP address of the hostname, enabling the request to reach internal resources. This vulnerability allows an attacker to interact with sensitive internal services that are otherwise protected from public access.

Proof of Concept (PoC):

An authenticated user provides a crafted hostname pointing to an internal-only IP address (e.g., 169.254.169.254) in a notification URL field. The server processes this hostname but fails to restrict resolution to safe network ranges, permitting the underlying request to connect to the internal service. The server subsequently returns the output of the internal request to the attacker. This results in the exposure of sensitive internal infrastructure and data.

\*\*Technical Details:\*\*

```

GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1

Host: target.com

```

\*\*curl command:\*\*

```bash

curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"

```

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-33655>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-33655>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-33655>

CVE-2026-34151

Finding: Resource Path Traversal in XWiki Platform

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-24

Score Provenance: Tenable Verified

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	None

Confidentiality Impact	High
Availability Impact	None

**Description:**

XWiki Platform, when utilizing Jetty 12+, exhibits a resource path traversal vulnerability via the /skin/ action endpoint. The application fails to sanitize path inputs, allowing an attacker to navigate outside the intended directory structure. This vulnerability allows unauthorized access to sensitive files on the host system that are intended to remain private.

**Proof of Concept (PoC):**

An unauthenticated attacker sends a HTTP request to the /skin/ endpoint using a path traversal sequence like '../' in the resource parameter. The backend, running on Jetty 12+, fails to normalize the path correctly and resolves it against the filesystem root. This allows the attacker to read arbitrary system files by observing the response content. This results in significant information disclosure of sensitive configuration files.

**\*\*Technical Details:\*\***

```

GET /assets/../../../../etc/passwd HTTP/1.1

Host: target.com

```

**\*\*curl command:\*\***

```bash

curl "https://target.com/assets/../../../../etc/passwd"

```

The server returns the contents of /etc/passwd, confirming path traversal.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-34151>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-34151>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-34151>

**CVE-2026-55792**

**Finding: Sensitive File Disclosure in Craft CMS**

**CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200**

Score Provenance: Tenable Verified

MITRE ATT&CK: T1552

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

**Description:**

Craft CMS contains a vulnerability that allows for sensitive file disclosure or Server-Side File Read. The vulnerability arises from an endpoint that accepts arbitrary path inputs without proper validation of the directory traversal constraints. This enables an authenticated attacker to read system files or application source code that should not be publicly accessible.

**Proof of Concept (PoC):**

An authenticated attacker interacts with a file-reading utility endpoint within the Craft CMS backend. The attacker passes a crafted relative path using sequences like '../' to target sensitive configuration files such as '.env'. The server fails to validate the directory bounds, reading the target file and returning its contents in the HTTP response. This results in the exposure of database credentials and system configuration.

**\*\*Technical Details:\*\***

...

GET /assets/../../../../etc/passwd HTTP/1.1

Host: target.com

...

**\*\*curl command:\*\***

```bash

curl "https://target.com/assets/../../../../etc/passwd"

...

The server returns the contents of /etc/passwd, confirming path traversal.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-55792>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-55792>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-55792>

CVE-2026-26193

Finding: Stored XSS via iFrame in Open WebUI

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 66/100 | CWE: CWE-79

Score Provenance: CVE.org Verified

MITRE ATT&CK: T1189

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:N

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | High |

| | |
|------------------------|----------|
| Attack Complexity | Low |
| User Interaction | Required |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

The Open WebUI component fails to sanitize iFrame embeds within incoming response messages. This vulnerability is caused by improper handling of user-supplied HTML content which is rendered directly in the user's browser session. An authenticated attacker can leverage this to execute arbitrary JavaScript in the context of a victim's session, leading to potential session hijacking or data theft.

Proof of Concept (PoC):

An authenticated user with low privileges targets the messaging interface. The attacker sends a chat response containing a crafted iFrame element pointing to a malicious external script. The Open WebUI client renders the iFrame without adequate escaping, executing the script in the context of the victim's browser. This allows the attacker to steal CSRF tokens or perform unauthorized actions on behalf of the victim.

****Technical Details:****


```

GET /search?q=<img src=x onerror=alert(1)> HTTP/1.1  
Host: target.com

```

****curl command:****
``bash
curl "https://target.com/search?q="
``

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-26193>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-26193>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-26193>

CVE-2026-26192

Finding: Stored XSS in Open WebUI Citations Model

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 66/100 | CWE: CWE-79

Score Provenance: *CVE.org Verified*
MITRE ATT&CK: *T1189*

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:N

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | High |

| | |
|------------------------|----------|
| Attack Complexity | Low |
| User Interaction | Required |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

The citations model within Open WebUI improperly handles iFrame tags provided within citation data fields. The underlying failure is due to a lack of sanitization for user-controllable input rendered in the application's user interface. This flaw allows an attacker to execute malicious scripts within a victim's session, compromising the confidentiality and integrity of their interaction.

Proof of Concept (PoC):

An authenticated attacker supplies a citation string containing a malicious iFrame embed to the citations API. When a target user views the generated response, the citation component renders the unvalidated iFrame. The embedded script executes within the victim's security context, enabling access to sensitive UI data or account session tokens. This results in the complete compromise of the victim's session integrity.

****Technical Details:****
```

GET /search?q=<img src=x onerror=alert(1)> HTTP/1.1  
Host: target.com  
``

**\*\*curl command:\*\***  
``bash

```
curl "https://target.com/search?q="
...
```

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-26192>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-26192>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-26192>

CVE-2026-55501

Finding: Brute-Force Bypass via Spoofed Header in 9router

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 66/100 | CWE: CWE-290

Score Provenance: CVE.org Verified  
MITRE ATT&CK: T1110

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	Low	Availability Impact	Low

Description:

9router is vulnerable to a login brute-force protection bypass through the exploitation of the X-Forwarded-For HTTP header. The system relies on this header for IP-based rate limiting, which can be easily spoofed by an attacker to represent different origin addresses. This vulnerability permits an attacker to perform credential stuffing or brute-force attacks against user accounts without triggering account lockouts.

Proof of Concept (PoC):

An attacker initiates a brute-force login attempt against the 9router login portal. For every request, the attacker modifies the 'X-Forwarded-For' header to a random or rotating IP address. The application backend evaluates the rate limit based on the header value rather than the true source IP. This successfully circumvents the security mechanism, allowing the attacker to continue attempts indefinitely.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-55501>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-55501>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-55501>

CVE-2026-35341

Finding: Insecure Permission Changes in mkfifo

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-281

Score Provenance: CVE.org Verified  
MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Local	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High

Integrity Impact

High

Availability Impact

None

**Description:**

The 'mkfifo' utility improperly modifies the permissions of existing files when a FIFO creation process fails. This vulnerability is caused by an error in the atomicity of the operation, where the code proceeds to chmod a file regardless of the creation outcome. This flaw allows a local user to potentially change permissions on files they do not own, leading to unauthorized access.

**Proof of Concept (PoC):**

A local attacker points 'mkfifo' to an existing file that they should not have write permissions to modify. The creation fails as the file already exists, but the 'mkfifo' logic erroneously triggers a chmod call on the path. The utility then changes the permissions of the existing file to an insecure state. This allows the attacker to then access or modify the contents of the file.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-35341>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-35341>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-35341>

**CVE-2026-45016****Finding: Local File Inclusion in EGroupware Mail Compose**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 58/100 | CWE: CWE-73

Score Provenance: Tenable Verified

MITRE ATT&CK: T1552

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

**Description:**

The EGroupware mail compose feature allows Local File Inclusion (LFI) via improper handling of file:// URI schemes. The application fails to validate protocol prefixes, allowing an attacker to reference local system files instead of network resources. This vulnerability allows for unauthorized reading of sensitive local files, which may contain configuration data or system credentials.

**Proof of Concept (PoC):**

An authenticated user triggers the mail compose function within EGroupware. The attacker modifies the attachment parameter in the request to include a 'file:///etc/passwd' URI. The backend processes this input without verifying the resource location, subsequently returning the contents of the file in the email preview. This allows the attacker to exfiltrate sensitive local files from the server.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-45016>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-45016>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-45016>

**CVE-2026-44512****Finding: Null Pointer Dereference in ONNX Upsample Converter**

CVSS v3.1 Score: 5.5 | Severity: Medium | Urgency Score: 50/100 | CWE: CWE-476

Score Provenance: CVE.org Verified

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

The ONNX Upsample version converter adapter is susceptible to a null pointer dereference when processing zero-length inputs. The fault occurs when the converter fails to initialize or validate the input buffer before attempting to access its memory address. This condition results in an application crash, causing a Denial of Service (DoS) vulnerability triggered by an attacker-controlled input file.

Proof of Concept (PoC):

A user provides a specially crafted ONNX model file containing an empty Upsample operator to the converter tool. Upon processing, the converter logic attempts to reference the memory block allocated for the operator inputs, which has not been initialized. The application subsequently dereferences the null pointer and terminates abnormally. This successfully causes a local Denial of Service condition on the machine processing the model.

\*\*Technical Details:\*\*

\*\*\*

An attacker sends a specially crafted input that triggers resource exhaustion.  
For example, a deeply nested structure or a massive list can consume CPU or memory.

\*\*curl command (conceptual):\*\*

```
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-44512>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-44512>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-44512>

CVE-2025-46719

Finding: Full Account Takeover and RCE in Open WebUI

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 49/100 | CWE: CWE-79

Score Provenance: Tenable Verified

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N

|                     |         |
|---------------------|---------|
| Attack Vector       | Network |
| Privileges Required | Low     |
| Scope               | Changed |

|                        |          |
|------------------------|----------|
| Attack Complexity      | Low      |
| User Interaction       | Required |
| Confidentiality Impact | Low      |

|                  |     |                     |      |
|------------------|-----|---------------------|------|
| Integrity Impact | Low | Availability Impact | None |
|------------------|-----|---------------------|------|

Description:

The MarkdownTokens.svelte component in Open WebUI is vulnerable to stored Cross-Site Scripting (XSS) due to unescaped markdown token processing. This vulnerability stems from the direct rendering of input that can be manipulated to inject malicious scripts, leading to complete client-side compromise. Attackers can escalate these privileges to achieve Remote Code Execution (RCE) via the application's function extension framework.

Proof of Concept (PoC):

An authenticated attacker submits a malicious markdown snippet containing a payload designed to target the MarkdownTokens.svelte component. The application fails to sanitize the input, executing the payload as a script within the user's browser. The script then interacts with the internal function registry to call administrative commands. This leads to full account takeover and execution of arbitrary code on the host server.

Technical Details:

```
GET /search?q= HTTP/1.1
Host: target.com

curl command:
bash
curl "https://target.com/search?q="
```

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2025-46719>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2025-46719>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2025-46719>

CVE-2025-46571

Finding: Stored XSS via File Upload in Open WebUI

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 49/100 | CWE: CWE-79

Score Provenance: Tenable Verified  
MITRE ATT&CK: T1189

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N

|                     |         |                        |          |
|---------------------|---------|------------------------|----------|
| Attack Vector       | Network | Attack Complexity      | Low      |
| Privileges Required | Low     | User Interaction       | Required |
| Scope               | Changed | Confidentiality Impact | Low      |
| Integrity Impact    | Low     | Availability Impact    | None     |

Description:

Open WebUI allows for stored Cross-Site Scripting (XSS) through the uploading of malicious HTML files. The root cause is a failure to properly validate or sanitize the content of uploaded documents before they are hosted or rendered by the application. This vulnerability enables an attacker to deliver persistent malicious payloads to other users who access the uploaded content.

Proof of Concept (PoC):

An authenticated user uploads an HTML file containing an embedded script payload through the file-upload feature. When another user navigates to the URL associated with the uploaded file, the malicious content is rendered in their browser session. The script executes without authorization, potentially accessing session-specific information. This results in the compromise of the victim's session integrity.

\*\*Technical Details:\*\*

...

GET /search?q=<img src=x onerror=alert(1)> HTTP/1.1

Host: target.com

...

\*\*curl command:\*\*

```bash

curl "https://target.com/search?q="

...

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2025-46571>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2025-46571>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2025-46571>

CVE-2026-55793

Finding: Stored XSS in Craft CMS Structure Title

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 49/100 | CWE: CWE-79

Score Provenance: Tenable Verified

MITRE ATT&CK: T1189

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N

| | |
|---------------------|---------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Changed |
| Integrity Impact | Low |

| | |
|------------------------|----------|
| Attack Complexity | Low |
| User Interaction | Required |
| Confidentiality Impact | Low |
| Availability Impact | None |

Description:

Craft CMS is susceptible to stored Cross-Site Scripting (XSS) due to improper validation of the Structure entry title when displayed in a table view. The application fails to properly encode the title content, permitting the injection of arbitrary HTML and script elements. When a user views the structure management table, the malicious script executes within their session.

Proof of Concept (PoC):

An authenticated user creates a structure entry with a title containing a malicious JavaScript payload. When an administrator navigates to the list view, the Craft CMS table component renders the entry title without sanitization. The script executes in the administrator's browser, potentially allowing the attacker to perform unauthorized management operations. This results in the compromise of the administrator's account session.

Technical Details:

```

GET /search?q=<img src=x onerror=alert(1)> HTTP/1.1

Host: target.com

```

****curl command:****

```bash

curl "https://target.com/search?q=<img src=x onerror=alert(1)>"

```

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-55793>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-55793>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-55793>

CVE-2026-44342

Finding: Cross-Site Request Forgery in New API

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-352

Score Provenance: CVE.org Verified

MITRE ATT&CK: T1526

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	None
Availability Impact	None

Description:

The New API endpoint is vulnerable to Cross-Site Request Forgery (CSRF) during the user email binding process. The implementation fails to enforce anti-CSRF tokens or verify the origin of the request, allowing unauthorized state changes. An attacker can trick a victim into submitting a request that binds an attacker-controlled email address to the victim's account.

Proof of Concept (PoC):

The attacker creates a malicious webpage designed to automatically send a POST request to the target API's email binding endpoint. The victim visits the page while logged into the application, causing their browser to send the unauthorized request. The API processes the request without validating the origin or using tokens, successfully changing the associated email. This results in the attacker gaining the ability to reset the victim's password.

****Technical Details:****

```

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-44342>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-44342>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-44342>

CVE-2026-55630

Finding: Stored XSS in Kiwi TCMS

CVSS v3.1 Score: 4.6 | Severity: Medium | Urgency Score: 41/100 | CWE: CWE-79

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1189

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | Low       |

|                        |          |
|------------------------|----------|
| Attack Complexity      | Low      |
| User Interaction       | Required |
| Confidentiality Impact | Low      |
| Availability Impact    | None     |

Description:

Kiwi TCMS is vulnerable to stored Cross-Site Scripting (XSS) via the 'extra\_link' field in the TestPlan and TestCase modules. The issue arises from the application's failure to filter 'javascript:' URI schemes, which are then rendered as clickable links. An attacker can exploit this to execute malicious JavaScript in the context of another user's session.

Proof of Concept (PoC):

An authenticated attacker creates or edits a TestPlan and injects a 'javascript:alert(1)' URI into the 'extra\_link' field. When another user views this TestPlan and clicks the link, the browser executes the script in the context of the user's session. This allows the attacker to perform actions as the victim or steal session cookies. The impact is a compromise of the victim's session integrity.

\*\*Technical Details:\*\*

```
...
GET /search?q= HTTP/1.1
Host: target.com
...

curl command:
```bash
curl "https://target.com/search?q=<img src=x onerror=alert(1)>"
...

```

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-55630>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-55630>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-55630>

CVE-2026-35361

Finding: Mislabeled SELinux Device Nodes via mknod

CVSS v3.1 Score: 3.4 | Severity: Low | Urgency Score: 26/100 | CWE: CWE-281

Score Provenance: CVE.org Verified

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Local
Privileges Required	High
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The 'mknod' utility fails to correctly label device nodes under SELinux security policies when an error occurs during creation. The issue is caused by a flawed cleanup routine that attempts 'remove_dir' on a node, leaving it in an insecure or mislabeled state. This creates a risk where device nodes may be accessible to unauthorized users or processes.

Proof of Concept (PoC):

An administrator executes 'mknod' in a manner that triggers a partial creation failure while SELinux is active. The cleanup function executes incorrectly, failing to remove the file while also failing to apply the correct security label. A subsequent user-space process may access the device node due to the incorrect labeling. This leads to a degradation of system security policy enforcement.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-35361>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-35361>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-35361>

CVE-2026-35381

Finding: Logic Error in cut Command Processing

CVSS v3.1 Score: 3.3 | Severity: Low | Urgency Score: 25/100 | CWE: CWE-684

Score Provenance: CVE.org Verified

MITRE ATT&CK: T1562

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The 'cut' utility fails to properly handle the '-s' flag when executed in conjunction with '-z' and '-d' newline-delimiter modes. This logic error causes the utility to ignore the 'suppress-lines' directive under specific delimiter conditions. The vulnerability results in unexpected data output which could affect automated scripts relying on output suppression.

Proof of Concept (PoC):

A local user executes 'cut' with the flags '-z', '-d' (null), and '-s' on a file that does not contain the delimiter. The utility, due to the logic error, proceeds to output the entire input stream instead of suppressing it as expected. This behavior alters the intended output of the command in a script context. The resulting integrity impact is limited to the incorrect processing of text data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-35381>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-35381>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-35381>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>